

IDENTITY & ACCESS MANAGEMENT FRAMEWORK IMPLEMENTATION

Microsoft Entra ID – Hands - On Security Configuration

M365 Security Portfolio - Project

Prepared by	Kapil Chaudhary - GRC & Cybersecurity Professional
Date	September 2026
Platform	Microsoft Entra ID (M365 E5 Trial Environment)
Framework Alignment	ISO 27001:2022, SOC 2, NIST CSF, PCI DSS
GitHub	github.com/ethicalkaps

Executive Summary

This document presents a complete Identity and Access Management (IAM) framework implemented from scratch in Microsoft Entra ID within a Microsoft 365 E5 environment. The project demonstrates hands- on capability in configuring enterprise- grade identity security controls, including user provisioning, security group management, Conditional Access policies, Privileged Identity Management (PIM), and automated access reviews.

Every configuration in this document maps to specific compliance requirements across ISO 27001:2022, SOC 2 Trust Service Criteria, NIST CSF, and PCI DSS - demonstrating not just technical skill but the ability to connect security configurations to governance, risk, and compliance objectives.

This is Project 1 of a 5- project Microsoft Security Portfolio. All projects are documented with screenshots, compliance mappings, and practical implementation notes suitable for audit evidence and portfolio demonstration.

Compliance Mapping Overview

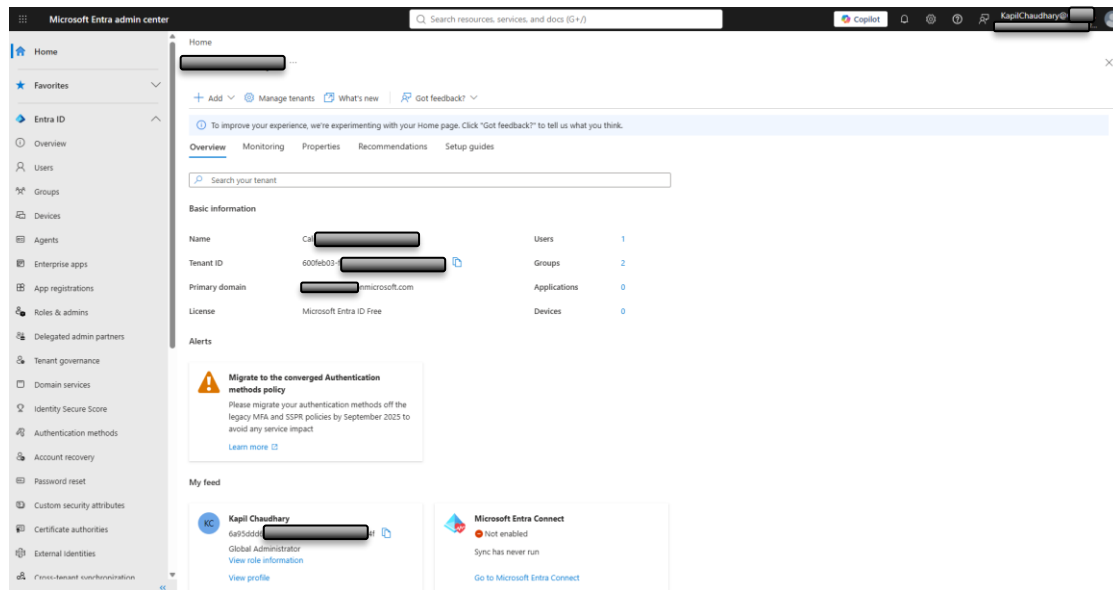
Each configuration in this project maps to one or more compliance framework controls. The following table provides a summary of all mappings covered in this implementation.

Configuration	ISO 27001 Control	SOC 2 Criteria
User Provisioning (role- based)	A.9.2.1 - User registration & de- registration	CC6.1 - Logical access controls
Security Groups (privilege- based)	A.9.2.2 - User access provisioning	CC6.2 - Access based on authorization
CA- 001: MFA for Privileged Users	A.9.4.2 - Secure log- on procedures	CC6.1 - Authentication mechanisms
CA- 002: Block Legacy Auth	A.9.4.1 - Information access restriction	CC6.1 - Logical access controls
CA- 003: Compliant Device for Finance	A.9.4.1 + A.11.2.6 - Equipment security	CC6.1 + CC6.8 - Endpoint controls
Quarterly Access Review (AR- 001)	A.9.2.5 - Review of user access rights	CC6.1 - Periodic access reviews
Named Locations	A.9.4.1 - Information access restriction	CC6.1 - Location- based controls
Privileged Identity Management	A.9.2.3 - Mgmt of privileged access rights	CC6.1 - Just- in- time access
Sign- in Logs & Risky Users	A.12.4.1 - Event logging	CC7.2 - Anomaly detection
Authentication Methods	A.9.4.2 - Secure log- on procedures	CC6.1 - MFA enforcement
Identity Security Score	A.18.2.1 - Independent review of info security	CC4.1 - Monitoring activities

1. Environment Overview

The Microsoft Entra ID tenant was provisioned as part of a Microsoft 365 E5 trial environment, providing access to the full enterprise security stack including Entra ID P2 (Conditional Access, PIM, Access Reviews), Microsoft Defender, Microsoft Intune, and Microsoft Purview.

Entra ID Dashboard



2. User Provisioning

Five users were created with proper organizational attributes - job title, department, employee ID, country, and city. Proper attribute population is critical for compliance because group- based policies, access reviews, and audit reports all depend on accurate user metadata. In a real organization, incomplete user profiles create gaps in compliance evidence.

2.1 User Creation Process

Each user was provisioned with role- appropriate attributes reflecting a realistic organizational structure spanning IT, Finance, and Human Resources departments.

Microsoft Entra admin center

Search resources, services, and docs (G+)

Copilot

Karel'shaufen

Home

Favorites

Entra ID

Overview

Users

Groups

Devices

Agents

Enterprise apps

App registrations

Roles & admins

Delegated admin partners

Tenant governance

Domain services

Conditional Access

Multifactor authentication

Identity Secure Score

Authentication methods

Account recovery

Password reset

Custom security attributes

Certificate authorities

External identities

Cross-tenant synchronization

Home > Security > Identity Secure Score > Users

Create new user

Create a new internal user in your organization

Basics Properties Assignments Review + create

Create a new user in your organization. This user will have a user name like `alice@contoso.com`. [Learn more](#)

Identity

User principal name * [Domain not listed? Learn more](#)

Mail nickname *

☒ Derive from user principal name

Display name *

Password *

☒ Auto-generate password

Account enabled ☒

[Review + create](#) [< Previous](#) [Next: Properties >](#) [Give feedback](#)

Microsoft Entra admin center

Search resources, services, and docs (G+)

Copilot

Karel'shaufen

Home

Favorites

Entra ID

Overview

Users

Groups

Devices

Agents

Enterprise apps

App registrations

Roles & admins

Delegated admin partners

Tenant governance

Domain services

Conditional Access

Multifactor authentication

Identity Secure Score

Authentication methods

Account recovery

Password reset

Custom security attributes

Certificate authorities

External identities

Cross-tenant synchronization

Home > Security > Identity Secure Score > Users

Create new user

Create a new internal user in your organization

Basics Properties Assignments Review + create

Identity

First name

Last name

User type

Authorization info [+ Edit Certificate user IDs](#)

Job Information

Job title

Company name

Department

Employee ID

Employee type

Employee hire date

Office location

Manager [+ Add manager](#)

Contact Information

Street address

City

State or province

ZIP or postal code

Country or region

Business phone

[Review + create](#) [< Previous](#) [Next: Assignments >](#)

Microsoft Entra admin center

Search resources, services, and docs (G+/)

Home

Favorites

Entra ID

Overview

Users

Groups

Devices

Agents

Enterprise apps

App registrations

Roles & admins

Delegated admin partners

Tenant governance

Domain services

Conditional Access

Multifactor authentication

Identity Secure Score

Authentication methods

Account recovery

Password reset

Custom security attributes

Certificate authorities

External Identities

Cross-tenant synchronization

Home > Security | Identity Secure Score > Users

Create new user

Create a new internal user in your organization

Basics Properties Assignments Review + create

Basics

User principal name sarah.chen@contoso.com

Display name Sarah Chen

Mail nickname sarah.chen

Password *****

Account enabled Yes

Properties

City Toronto

State or province Ontario

Country or region Canada

First name Sarah

Last name Chen

User type Member

Job title Cloud Engineer

Department IT

Employee ID 1001

Employee type Permanent

Employee hire date Sep 1, 2026, 12:00 AM

Office location Toronto

Age group Adult

Assignments

Administrative units

Groups

Roles

Create Previous Next

2.2 Complete User Directory

All users provisioned with visible department, job title, employee ID, and location columns - demonstrating proper identity governance from the point of onboarding.

Home > Security | Identity Secure Score

Users

+ New user Edit Delete Download users (Preview) Bulk operations Refresh Manage view Per-user MFA Got feedback?

All users Audit logs Sign-in logs Diagnose and solve problems Deleted users Password reset User settings Bulk operation results Bulk operation results (Preview) New support request

6 users found

	Display name	User principal name	User type	Department	Employee ID	Job title	Country or region	City
☐	David Park	david.park@contoso.com	Member	IT	1004	Junior Developer	Canada	Toronto
☐	Divya Chopra	divya.chopra@contoso.com	Member	Human Resources	1003	HR Manager	Canada	Toronto
☐	James Wilson	james.wilson@contoso.com	Member	Finance	1002	Finance Analyst	Canada	Toronto
☐	Kapil Chaudhary	KapilChaudhary@contoso.com	Member	Security and Compliance	1000	GRC Analyst	Canada	Mississauga
☐	Lisa Thompson	lisa.thompson@contoso.com	Member	IT	1005	IT Administrator	Canada	Toronto
☐	Sarah Chen	sarah.chen@contoso.com	Member	IT	1001	Cloud Engineer	Canada	Toronto

ISO 27001 Reference: A.9.2.1 - User registration and de- registration. SOC 2: CC6.1 - Logical and physical access controls.

3. Security Group Configuration

Three security groups were created to segment users by access level and organizational function. Groups serve as the foundation for Conditional Access policies and access reviews - policies are applied to groups, not individual users, ensuring scalable and consistent security enforcement.

3.1 Group Structure

SG- Privileged- Users: Contains users with elevated access (IT Administrator, Cloud Engineer). SG- Standard- Users: Contains standard business users (Finance Analyst, HR Manager, Junior Developer). SG- IT- Department: Contains all IT personnel for department- level policy targeting.

The screenshot displays the Microsoft Entra ID 'All groups' page. The left sidebar shows the navigation menu with 'Groups' selected. The main area shows a table of groups with columns: Name, Object ID, Group type, Membership type, Email, and Source. Two groups are listed: 'All Company' and 'Callan Group'. Below the table, the 'New Group' dialog is open, showing fields for Group type (Security), Group name (SG-Privileged-Users), Group description (Users with elevated access to production systems), and Membership type (Assigned). The 'Owners' section shows two users selected: Lisa Thompson and Sarah Chen.

Name	Object ID	Group type	Membership type	Email	Source
All Company	36c5b...	Microsoft 365	Assigned	allcompany@...com	Cloud
Callan Group	9130c...	Microsoft 365	Assigned	callan@...com	Cloud

New Group

Group type: Security

Group name: SG-Privileged-Users

Group description: Users with elevated access to production systems

Microsoft Entra roles can be assigned to the group: ☐

Membership type: Assigned

Owners: 2 owners selected

Members: No members selected

Add owners

Search: 6 results found

Name	User principal name
David Park	david.park@...com
Olivia Chopra	olivia.chopra@...com
James Wilson	james.wilson@...com
Kapil Chaudhary	kapil.chaudhary@...com
Lisa Thompson	lisa.thompson@...com
Sarah Chen	sarah.chen@...com

Owners (2): Lisa Thompson, Sarah Chen

3.2 Group Membership Configuration

Critical distinction: users were added as Members (receive policies and access) with appropriate Owners (manage group membership). During initial setup, all users were incorrectly added as Owners instead of Members - a mistake that was caught and corrected, demonstrating the importance of verifying member vs. owner assignments before building policies on top of group membership.

Home > SG-IT-Department > Groups | All groups > SG-Privileged-Users | Owners > Groups | All groups > SG-Standard-Users | Members > Groups

Groups | All groups

New groupDownload groupsRefreshManage viewDeleteGot feedback?

SearchAdd filter

Search modeContains

5 groups found

☐	Name	Object Id	Group type	Membership type	Email	Source
☐	All Company	36c56147-...	Microsoft 365	Assigned	allcompany@...	Cloud
☐	Calian Group	913cc711-...	Microsoft 365	Assigned	CalianGroup@...	Cloud
☐	SG-IT-Department	1ef5df08-...	Security	Assigned		Cloud
☐	SG-Privileged-Users	3be880ad-...	Security	Assigned		Cloud
☐	SG-Standard-Users	a8510772-...	Security	Assigned		Cloud

Home > SG-IT-Department > Groups | All groups > SG-Privileged-Users | Owners > Groups | All groups > SG-Standard-Users | Members > Groups | All groups > SG-IT-Department

SG-IT-Department | Members

Add membersBulk operationsRefreshManage viewRemoveGot feedback?

SearchAdd filter

3 group members found

☐	Name	Type	Email	User type	Object Id	Device Id
☐	David Park	User		Member	b806d03e-8...	
☐	Lisa Thompson	User		Member	f69377b3-00...	
☐	Sarah Chen	User		Member	3b13579a-b...	

Home > SG-IT-Department > Groups | All groups > SG-Privileged-Users | Owners > Groups | All groups > SG-Standard-Users | Members > Groups | All groups > SG-Privileged-Users

SG-Privileged-Users | Members

Add membersBulk operationsRefreshManage viewRemoveGot feedback?

SearchAdd filter

2 group members found

☐	Name	Type	Email	User type	Object Id	Device Id
☐	Lisa Thompson	User		Member	f69377b3-00...	
☐	Sarah Chen	User		Member	3b13579a-b...	

Home > SG-IT-Department > Groups | All groups > SG-Privileged-Users | Owners > Groups | All groups > SG-Standard-Users | Members > Groups | All groups > SG-Standard-Users

SG-Standard-Users | Members

Overview, Diagnose and solve problems, Manage, Properties, **Members**, Owners, Roles and administrators, Administrative units, Group memberships, Applications, Licenses, Azure role assignments, Activity, Privileged Identity Management, Access reviews, Audit logs, Bulk operation results, Troubleshooting > Support, New support request

Direct members All members

Search Add filter

3 group members found

☐	Name	Type	Email	User type	Object Id	Device Id
☐	David Park	User		Member	b806d03e-8...	
☐	Divya Chopra	User		Member	e3f6b17-fb...	
☐	James Wilson	User		Member	4d121e6d-b...	

ISO 27001 Reference: A.9.2.2 - User access provisioning. SOC 2: CC6.2 - Prior to issuing system credentials, registered authorized users are verified.

4. Conditional Access Policies

Three Conditional Access policies were configured to enforce identity- based security controls. All policies were deployed in Report- only mode first - the recommended approach for production environments to assess impact before enforcement, preventing unintended access disruptions.

4.1 Security Defaults Migration

Before creating Conditional Access policies, Security Defaults were disabled. Microsoft tenants include Security Defaults as a basic security baseline, but Conditional Access provides the granular, customizable control required by enterprise compliance programs. The two cannot run simultaneously - Conditional Access replaces Security Defaults.

Domain names, Custom branding, Mobility, Monitoring & health, ID Protection, Risk-based Conditional Access, Risky users, Risky workload identities, Risky agents, ID Governance, Entitlement management, Access reviews, Privileged Identity Management, Lifecycle workflows, Verified ID, Overview, Credentials, Organization settings, Global Secure Access, What's new, Billing

Groups | All groups > SG-Privileged-Users | Owners > Groups | All groups > SG-Standard-Users | Members > Groups | All groups > SG-Standard-Users | Members > Conditional Access | Policies > Create new policy from templates > Conditional Access | Policies

New

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name * CA-002: Block Legacy Authentication

Assignments

Users

Target resources

Network

Conditions

Access controls

Grant

Session

Enable policy

It looks like you're about to manage your organization's security configurations. That's great! You must first **disable security defaults** before enabling a Conditional Access policy.

Don't lock yourself out! We recommend applying a policy to a small set of users first to verify it behaves as expected. We also recommend excluding at least one administrator from this policy. This ensures that you still have access and can update a policy if a change is required. Please review the affected users and [learn more](#).

☒ Exclude current user, KapiChaudhary@CalanGroup22.onmicrosoft.com, from this policy.

☐ I understand that my account will be impacted by this policy. Proceed anyway.

Create

New Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies.

Name: CA-001: Block Legacy Authentication

Assignments: Users: All users

Target resources: All resources (formerly 'All cloud apps')

Network: Not configured

Conditions: 1 condition selected

Access controls: Grant: Block access

Session: 0 controls selected

Enable policy: Report only (On)

It looks like you're about to manage your organization's security configurations. That's great! You must first [disable security defaults](#) before enabling a Conditional Access policy.

Don't lock yourself out! We recommend applying a policy to a small set of users first to verify it behaves as expected. We also recommend excluding at least one administrator from this policy. This ensures that you still have access and can update the policy.

Exclude current user: KapilChaudhary@celanagroup22.com@microsoft.com, from this policy.

I understand that my account will be impacted by this policy. Proceed anyway.

Security defaults

Security defaults: Disabled

With security defaults disabled, your organization is vulnerable to common identity-related attacks.

99.9% of account compromise could be stopped by using multifactor authentication, which is a feature that security defaults provides.

Microsoft's security teams see a drop of 80% in compromise rate when security defaults are enabled.

Reason for disabling

This feedback will be used to improve Microsoft products and services. [View privacy statement](#)

My organization is planning to use Conditional Access

Once you disabled security defaults, your organization will not be protected until you create Conditional Access policies to protect your identities. [Learn more](#)

Too many multifactor authentication sign-up requests

My organization is unable to use apps/devices

Too many sign-in multifactor authentication challenges

Other

Create

Note: Migration from Security Defaults to Conditional Access is a common enterprise project. Security Defaults are appropriate for small organizations; enterprises require Conditional Access for role- based, location- based, and device-based policy granularity.

4.2 CA- 001: Require MFA for Privileged Users

Multi- factor authentication enforced for all members of SG- Privileged- Users across all cloud applications. MFA for privileged accounts is the single most frequently tested control in ISO 27001 and SOC 2 audits. Advisory language ('recommended' or 'encouraged') is not auditable - MFA must be mandatory and verifiable.

New Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies.

Name: CA-001: Require MFA for Privileged Users

Assignments: Users: Specific users included

Target resources: No target resources selected

Network: Not configured

Conditions: 0 conditions selected

Access controls: Grant: 0 controls selected

Session: 0 controls selected

Enable policy: Report only (On)

It looks like you're about to manage your organization's security configurations. That's great! You must first [disable security defaults](#) before enabling a Conditional Access policy.

Select users and groups

Try changing or adding filters if you don't see what you're looking for.

11 results found

Groups

SG-Privileged-Users

Create

Home

Favorites

Entra ID

ID Protection

Risk-based Conditional Access

Risky users

Risky workload identities

Risky agents

ID Governance

Verified ID

Global Secure Access

What's new

Billing

Security Store

Diagnose & solve problems

New support request

Groups | All groups | SG-Privileged-Users | Owners | Groups | All groups | SG-Standard-Users | Members | Groups | All groups | SG-Standard-Users | Members | Conditional Access | Policies | Create new policy from templates | Conditional Access | Policies

New

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Control access based on all or specific apps, agents, internet resources, actions, or authentication context. [Learn more](#)

Select what this policy applies to

Name *

CA-001: Require MFA for Privileged Users

Include

Exclude

☐ None

☐ All internet resources with Global Secure Access

☐ All agent resources (Preview)

☒ All resources (formerly 'All cloud apps')

☐ Select resources

Target resources

All resources (formerly 'All cloud apps')

Network

Not configured

Conditions

0 conditions selected

Access controls

Grant *

0 controls selected

Session *

0 controls selected

Enable policy

Report only

On

Off

It looks like you're about to manage your organization's security configurations. That's great! You must first [enable security defaults](#) before enabling a Conditional Access policy.

Create

Home

Favorites

Entra ID

ID Protection

Risk-based Conditional Access

Risky users

Risky workload identities

Risky agents

ID Governance

Verified ID

Global Secure Access

What's new

Billing

Security Store

Diagnose & solve problems

New support request

Groups | All groups | SG-Privileged-Users | Owners | Groups | All groups | SG-Standard-Users | Members | Groups | All groups | SG-Standard-Users | Members | Conditional Access | Policies | Create new policy from templates | Conditional Access | Policies

New

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Control access enforcement to block or grant access. [Learn more](#)

Name *

CA-001: Require MFA for Privileged Users

Target resources

All resources (formerly 'All cloud apps')

Access controls

Grant *

0 controls selected

Session *

0 controls selected

Enable policy

Report only

On

Off

It looks like you're about to manage your organization's security configurations. That's great! You must first [enable security defaults](#) before enabling a Conditional Access policy.

Create

Grant

Control access enforcement to block or grant access. [Learn more](#)

☐ Block access

☒ Grant access

☒ Require multifactor authentication

Consider testing the new 'Require authentication strength' - [Learn more](#)

☐ Require authentication strength

Require authentication strength "cannot be used with 'Require multifactor authentication'." - [Learn more](#)

☐ Require device to be installed as compliant

☐ Require Microsoft Entra hybrid joined device

☐ Require approved client app

See list of approved client apps

☐ Require app protection policy

See list of policy protected client apps

☐ Require password change

☐ Require risk remediation

For multiple controls

☒ Require all the selected controls

Select

Home

Favorites

Entra ID

ID Protection

Risk-based Conditional Access

Risky users

Risky workload identities

Risky agents

ID Governance

Verified ID

Global Secure Access

What's new

Billing

Security Store

Diagnose & solve problems

New support request

Groups | All groups | SG-Privileged-Users | Owners | Groups | All groups | SG-Standard-Users | Members | Groups | All groups | SG-Standard-Users | Members | Conditional Access | Policies | Create new policy from templates | Conditional Access | Policies

New

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Control access based on all or specific apps, agents, internet resources, actions, or authentication context. [Learn more](#)

Select what this policy applies to

Name *

CA-001: Require MFA for Privileged Users

Target resources

All resources (formerly 'All cloud apps')

Access controls

Grant *

1 control selected

Session *

0 controls selected

Enable policy

Report only

On

Off

It looks like you're about to manage your organization's security configurations. That's great! You must first [enable security defaults](#) before enabling a Conditional Access policy.

Create

... > SG-Privileged-Users | Owners > Groups | All groups > SG-Standard-Users | Members > Groups | All groups > SG-Standard-Users | Members > Conditional Access | Policies > Create new policy from templates > Conditional Access | Policies > Conditional Access

Conditional Access | Policies

Microsoft Entra ID

Overview

[+ New policy](#)
[+ New policy from template](#)
[Upload policy file](#)
[What if](#)
[Refresh](#)
[Preview features](#)
[Got feedback?](#)

Microsoft Entra Conditional Access policies are used to apply access controls to keep your organization secure. [Learn more](#)

Microsoft-managed policies

Policies created 0

User created policies

Policies created 1

Search policies [Add filter](#)

1 out of 1 policy found

Policy name	Created by	State	Alert	Creation date	Modified date
CA-001: Require MFA for Privileged Users	USER	Report-only		9/16/2026, 11:33:1...	---

[Named locations](#)
[Custom controls \(Preview\)](#)
[Terms of use](#)
[VPN connectivity](#)
[Authentication contexts](#)
[Authentication strengths](#)
[Classic policies](#)

[Monitoring](#)
[Sign-in logs](#)
[Audit logs](#)

[Troubleshooting + Support](#)
[New support request](#)

ISO 27001 Reference: A.9.4.2 - Secure log- on procedures. SOC 2: CC6.1 - Logical and physical access controls. PCI DSS: Requirement 8 - Identify and authenticate access.

4.3 CA- 002: Block Legacy Authentication

Legacy authentication protocols (POP3, IMAP, SMTP) do not support MFA, making them a common bypass vector even when MFA is enforced on modern authentication. This policy blocks Exchange ActiveSync clients and other legacy clients for all users. This is one of Microsoft's top Secure Score recommended actions.

... > Groups | All groups > SG-Privileged-Users | Owners > Groups | All groups > SG-Standard-Users | Members > Groups | All groups > SG-Standard-Users | Members > Conditional Access | Policies > Create new policy from templates > Conditional Access | Policies

New

Conditional Access policy

Control access based on who the policy will apply to, such as users and groups, workload identities, directory roles, or external guests. [Learn more](#)

Name *

What does this policy apply to?

Include Exclude

☐ None

☒ All users

☐ Select users and groups

Target resources

Network

Conditions

Access controls

Grant *

Session *

Enable policy ☒ Report-only On Off

It looks like you're about to manage your organization's security configurations. That's great! You must first [update security defaults](#) before enabling a Conditional Access policy.

Create

Home

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *
CA-002: Block Legacy Authentication

Assignments

Users
All users

Target resources
All resources (formerly: All cloud apps)

Network
Not configured

Conditions
0 conditions selected

Access controls

Grant *
0 controls selected

Session *
0 controls selected

Enable policy
Report only On Off

It looks like you're about to manage your organization's security configurations. That's great! You must first [disable security defaults](#) before enabling a Conditional Access policy.

Create

Client apps

Control user access to target specific client applications not using modern authentication. [Learn more](#)

Configure
No No

Select the client apps this policy will apply to

Modern authentication clients

☐ Browser

☐ Mobile apps and desktop clients

☒ Legacy authentication clients

☒ Exchange ActiveSync clients

☐ Other clients

Done

Microsoft Entra admin center

Search resources, services, and docs (Ctrl+Q)

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *
CA-002: Block Legacy Authentication

Assignments

Users
All users

Target resources
All resources (formerly: All cloud apps)

Network
Not configured

Conditions
1 condition selected

Access controls

Grant *
8 controls selected

Session *
0 controls selected

Enable policy
Report only On Off

It looks like you're about to manage your organization's security configurations. That's great! You must first [disable security defaults](#) before enabling a Conditional Access policy.

Create

Grant

Control access enforcement to block or grant access. [Learn more](#)

☒ Block access

☐ Grant access

☐ Require multifactor authentication

☐ Require authentication strength

☐ Require device to be marked as compliant

☐ Require Microsoft Entra hybrid joined device

☐ Require approved client app
[See list of approved client apps](#)

☐ Require app protection policy
[See list of policy protected client apps](#)

☐ Require password change

☐ Require risk remediation

For multiple controls

☒ Require all the selected controls

☐ Require one of the selected controls

Select

Microsoft Entra admin center

Home > Security > Authentication methods > Authentication methods > Settings > Conditional Access > Policies

New ...
Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies.
[Learn more](#)

Name *
CA-002: Block Legacy Authentication ✓

Assignments

Users ⓘ
[All users included and specific users excluded](#)

Target resources ⓘ
[All resources \(formerly 'All cloud apps'\)](#)

Network ⓘ
[Not configured](#)

Conditions ⓘ
[1 condition selected](#)

Access controls

Grant * ⓘ
[Block access](#)

Session * ⓘ
[0 controls selected](#)

Enable policy
[Report-only](#) On Off

Create

ISO 27001 Reference: A.9.4.1 - Information access restriction. SOC 2: CC6.1 - Logical access controls.

4.4 CA- 003: Require Compliant Device for Finance

Finance department users are required to access cloud applications only from devices marked as compliant in Microsoft Intune. This policy demonstrates the integration between Entra ID (identity) and Intune (endpoint compliance) - a cross- tool relationship critical for enterprise security posture. Deployed in Report- only mode with non- Windows platforms excluded for initial rollout stability.

Microsoft Entra admin center

Home > Security > Authentication methods > Authentication methods > Settings > Conditional Access > Policies

New ...
Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies.
[Learn more](#)

Name *
CA-003: Require Compliant Device for Finance ✓

What does this policy apply to?
Users and groups

Include Exclude

☒ None
☐ All users
☒ Select users and groups

☐ Guest or external users ⓘ
☐ Directory roles ⓘ

☒ Users and groups

Select

1 user
James Wilson
james.wilson@contoso.com

User-based policies apply when users access resources directly or through agents acting on the user's behalf.

Enable policy
[Report-only](#) On Off

Create

Microsoft Entra admin center

Search resources, services, and docs (G+/)

Entra ID

ID Protection

Dashboard

Risk-based Conditional Access

Risky users

Risky workload identities

Risky agents

ID Governance

Verified ID

Global Secure Access

Dashboard

Agents

Applications

Connect

Secure

Monitor

Settings

Third Party Security Solutions

What's new

Billing

Security Store

Diagnose & solve problems

New support request

Home > Security > Authentication methods > Authentication methods | Settings > Conditional Access | Policies

New

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *

CA-003: Require Compliant Device for Fin...

Assignments

Users

Specific users included

Target resources

All resources (formerly 'All cloud apps')

Network

Not configured

Conditions

0 conditions selected

Access controls

Grant *

0 controls selected

Session *

0 controls selected

Select what this policy applies to

Resources (formerly cloud apps)

Include

Exclude

None

All internet resources with Global Secure Access

All agent resources (Preview)

All resources (formerly 'All cloud apps')

Select resources

Don't lock yourself out! This policy impacts the Azure portal. Before you continue, ensure that you or someone else will be able to get back into the portal. Disregard this warning if you are configuring persistent browser session policy that works correctly only if "All resources" are selected. [Learn more](#)

To create a Conditional Access policy targeting members in your tenant with Global Secure Access (GSA) as a resource, make sure GSA is deployed in your tenant. [Learn more](#)

Enable policy

Report-only

On

Off

Create

Entra ID

ID Protection

Dashboard

Risk-based Conditional Access

Risky users

Risky workload identities

Risky agents

ID Governance

Verified ID

Global Secure Access

Dashboard

Agents

Applications

Connect

Secure

Monitor

Settings

Third Party Security Solutions

What's new

Billing

Security Store

Diagnose & solve problems

New support request

Home > Security > Authentication methods > Authentication methods | Settings > Conditional Access | Policies

New

Conditional Access policy

Control access based on Conditional Access policy to bring signals together, to make decisions, and enforce organizational policies. [Learn more](#)

Name *

CA-003: Require Compliant Device for Fin...

Assignments

Users

Specific users included

Target resources

All resources (formerly 'All cloud apps')

Network

Not configured

Conditions

0 conditions selected

Access controls

Grant *

0 controls selected

Session *

0 controls selected

Control access enforcement to block or grant access. [Learn more](#)

Block access

Grant access

Require multifactor authentication

Require authentication strength

Require device to be marked as compliant

Don't lock yourself out! Make sure that your device is compliant. [Learn more](#)

Require Microsoft Entra hybrid joined device

Require approved client app

See list of approved client apps

Require app protection policy

See list of policy protected client apps

Require password change

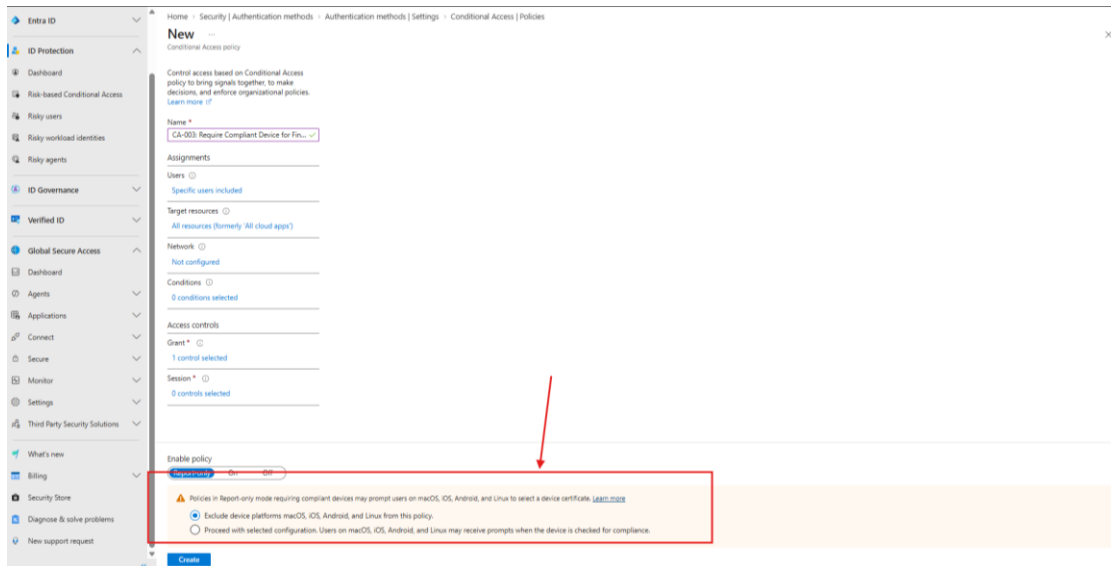
Require risk remediation

For multiple controls

Require all the selected controls

Require one of the selected controls

Select

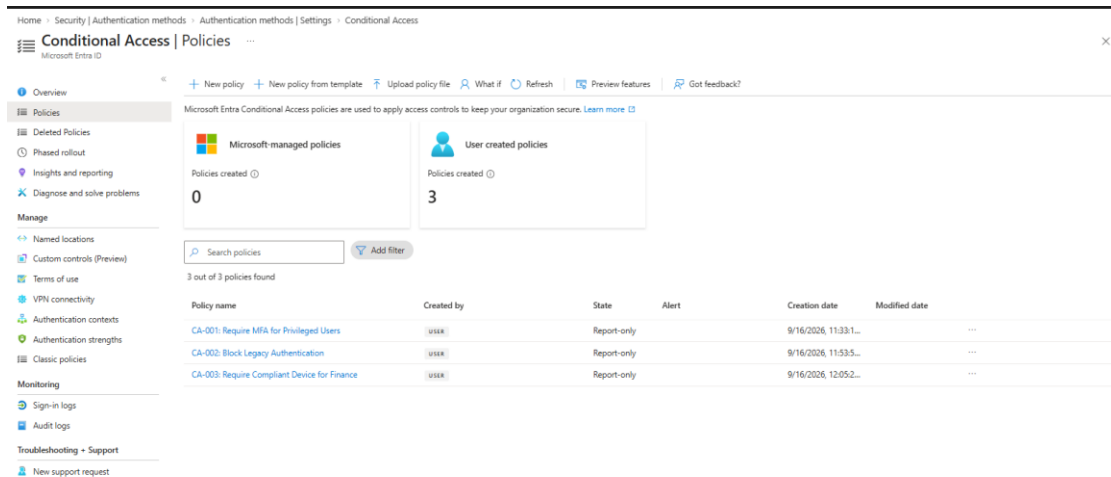


Note: In production, compliant device policies are deployed platform- by- platform - Windows first (deepest Intune integration), then macOS and mobile. Never enforced across all platforms simultaneously without validation.

ISO 27001 Reference: A.9.4.1 + A.11.2.6 - Equipment security. PCI DSS: Requirement 7 - Restrict access by business need-to-know.

4.5 All Policies - Summary View

All three Conditional Access policies deployed in Report-only mode, ready for impact analysis before enforcement.



5. Access Reviews - Automated Audit Control

Access Reviews are how organizations prove they regularly verify who has access to what. This is one of the most frequently tested controls in ISO 27001 and SOC 2 audits. When an auditor asks 'how do you ensure only authorized users have access,' the answer is 'we run quarterly access reviews in Entra ID and here is the evidence.'

5.1 AR- 001: Quarterly Privileged Access Review

A quarterly access review was configured for SG- Privileged- Users. Group owners are designated as reviewers with a 7- day completion window. If a reviewer does not respond within the window, access is automatically revoked - ensuring that unconfirmed privileges do not persist indefinitely.

Home > Security > Authentication methods > Authentication methods > Settings > Conditional Access > Policies > Identity Governance > Access reviews

Identity Governance | Access reviews

+ New access review Columns Refresh Get feedback?

Beginning January 15, 2025, a linked Azure subscription is required to use Entra ID Governance features for guest users. Billing is based on unique guest users included in Entra ID Governance features during the month. Link an Azure subscription to continue using Entra ID Governance features for guests. [Link Azure subscription](#)

Group and app Catalog reviews - multi-resource (preview)

Type Filter by access review type

Search by name or owner

Name	Resource	Status	Warning	Created On
No access review to display				

Microsoft Entra admin center Search resources, services, and docs (G+/I) Cop

Home > Security > Authentication methods > Authentication methods > Settings > Conditional Access > Policies > Identity Governance > Access reviews

Create an access review

Choose an Access Review template

Select an access review template, then edit the settings to fit your scenario.

Resource review

Review access to a resource type

Customize an access review of assignments to resource types such as groups, teams, applications, access packages, Entra ID roles, or Azure roles.

Select | Details

Catalog review

Review users access across multiple resource types within a catalog

Review users access across all resource types including Entra ID and Azure resources as well as non Entra ID and Azure resources.

Select | Details

Home

Favorites

Entra ID

ID Protection

ID Governance

Dashboard

Entitlement management

Access reviews

Privileged Identity Management

Lifecycle workflows

Verified ID

Global Secure Access

What's new

Billing

Security Store

Diagnose & solve problems

New support request

Home > Security > Authentication methods > Authentication methods > Settings > Conditional Access

New access review

Beginning January 15, 2026, a linked Azure subscription is required to use Entra ID Governance features for guest users.

Review type

Reviews

Settings

Review + Create

Schedule an access review to ensure the right people have the right access to access packages, groups, apps, or resources.

Select what to review *

Teams + Groups

Review scope *

All Microsoft 365 groups with guest users

Select Teams + groups

Group *

SG-Privileged-Users

Scope *

Guest users only

All users

In public preview, B2B direct connect users and teams in shared channels are included in access reviews. B2B direct connect users are not supported in reviews of All Microsoft 365 groups with guest users, as well as reviews scoped to inactive users only.

Inactive users only

Next: Reviews

Select group

Try changing or adding filters if you don't see what you're looking for

Search

3 results found

Groups

	Name	Email
☐	All Company	allcompany@
☐		
☐	SG-IT-Department	
☒	SG-Privileged-Users	
☐	SG-Standard-Users	

Selected groups (1)

Reset

SG-Privileged-Users

Select

Microsoft Entra admin center

Search resources, services, and docs (G+/)

Home > Security > Authentication methods > Authentication methods > Settings > Conditional Access > Policies > Identity Governance > Access reviews > Create an access review

New access review

Beginning January 15, 2026, a linked Azure subscription is required to use Entra ID Governance features for guest users. Billing is based on unique guest users included in Entra ID Governance features during the month.

Review type

Reviews

Settings

Review + Create

Determine review stages, reviewers, and timeline below.

Multi-stage review

Specify reviewers

Select reviewers *

Group owner(s)

Fallback reviewers

+ Select fallback reviewers

Specify recurrence of review

Duration (in days) *

7

Review recurrence *

Quarterly

Start date *

9/16/2026

End *

Never

End on specific date

End after number of occurrences

< Previous

Next: Settings

Microsoft Entra admin center

Search resources, services, and docs (G+/)

Home

Favorites

Entra ID

ID Protection

ID Governance

Dashboard

Entitlement management

Access reviews

Privileged Identity Management

Lifecycle workflows

Verified ID

Global Secure Access

What's new

Billing

Security Store

Diagnose & solve problems

New support request

Home > Security | Authentication methods > Authentication methods | Settings > Conditional Access | Policies > Identity Governance | Access reviews > Create an access review

New access review

Beginning January 15, 2026, a linked Azure subscription is required to use Entra ID Governance features for guest users. Billing is based on unique guest users included in Entra ID Governance features during

Review type | Reviews | Settings | Review + Create

Configure additional settings, including decision helpers and email notifications.

Upon completion settings

Auto apply results to resource

If reviewers don't respond

At end of review, send notification to

Enable reviewer decision helpers

No sign-in within 30 days

User-to-Group Affiliation

Advanced settings

Justification required

Email notifications

Reminders

Additional content for reviewer email

< Previous

Next: Review + Create

Microsoft Entra admin center

Search resources, services, and docs (G+/)

Home

Favorites

Entra ID

ID Protection

ID Governance

Dashboard

Entitlement management

Access reviews

Privileged Identity Management

Lifecycle workflows

Verified ID

Global Secure Access

What's new

Billing

Security Store

Diagnose & solve problems

New support request

Home > Security | Authentication methods > Authentication methods | Settings > Conditional Access | Policies > Identity Governance | Access reviews > Create an access review

New access review

Beginning January 15, 2026, a linked Azure subscription is required to use Entra ID Governance features for guest users. Billing is based on unique guest users included in Entra ID Governance features during the month. Link an Azure subscription to continue using Entra ID

Name new access review

Review name

Description

Confirm access review + create

Resources

Selected resource

1 group selected

Review scope

Everyone

Reviews

Reviewers

Group owner(s)

Frequency

Quarterly

End

No end

Settings

Auto-apply results to resource

Enabled

If reviewers don't respond

Remove access

Action to apply on denied guest users

Remove membership

At end of review, send notification to

0 selected user(s) or group(s)

Decision helpers

Enabled, 30 days with no sign-in activity

Justification required

Enabled

Email notifications

Enabled

Reminders

Enabled

< Previous

Create

Home > Security > Authentication methods > Authentication methods > Settings > Conditional Access > Policies > Identity Governance > Access reviews

AR-001: Quarterly Privileged Access Review | Overview

Overview

Current

Results

Reviewers

Settings

Audit logs

Series

Reviewers

Settings

Scheduled review

Review history

Audit logs

Delete series

Essentials

Owner : Kapi Chaudhary(KapiChaudhary@contoso.com)

Group : SG-Privileged-Users

Access review period : 9/16/2026 - No end date

Object ID : 39964953-5a...

Scope : Everyone

Review status : Not started

Selected reviewers : Resource owners

Description : Quarterly review of all members in SG-Privileged-Users to verify continued need for elevated a...

Recurrence type : Quarterly

ISO 27001 Reference: A.9.2.5 - Review of user access rights. SOC 2: CC6.1 - Periodic review of access privileges.

5.2 Audit Logs

Entra ID audit logs capture all identity governance activities including user provisioning, group modifications, policy changes, and access review actions. These logs serve as the evidence trail for compliance audits.

Account recovery

Password reset

Custom security attributes

Certificate authorities

External identities

Cross-tenant synchronization

Entra Connect

Backup and recovery

Domain names

Custom branding

Mobility

Monitoring & health

Sign-in logs

Audit logs

Provisioning logs

Health

Log Analytics

Diagnostic settings

Workbooks

Usage & insights

Bulk operations

ID Protection

ID Governance

Verified ID

Role setting details > User Administrator > Privileged Identity Management > My roles > My roles > Microsoft Entra roles > Sign-in events > Usage & insights > Microsoft Entra application activity (Preview) > Bulk Operations > Health > Sign-in events

Audit Logs

Download > Export Data Settings > Refresh > Manage view > Get feedback?

Want to switch back to the legacy audit logs experience? Click here to leave the preview.

Add filter > Show dates as: Local > Date range: Last 24 hours > Service: All > Category: All > Activity: All > Reset filters

Directory > Custom Security

Date	Service	Category	Activity	Status	Status Reason
9/16/2026, 12:25:19 PM	Core Directory	ApplicationManagement	Add owner to service pr...	Success	
9/16/2026, 12:25:18 PM	Core Directory	ApplicationManagement	Add service principal	Success	
9/16/2026, 12:25:18 PM	Core Directory	ApplicationManagement	Add owner to application	Success	
9/16/2026, 12:25:18 PM	Core Directory	ApplicationManagement	Add application	Success	
9/16/2026, 12:25:18 PM	Core Directory	ApplicationManagement	Create application - Cer...	Success	
9/16/2026, 12:25:18 PM	Core Directory	ApplicationManagement	Add service principal	Success	
9/16/2026, 12:25:14 PM	Conditional Access	Policy	Add named location	Success	
9/16/2026, 12:25:13 PM	Core Directory	Policy	Add policy	Success	
9/16/2026, 12:25:13 PM	Core Directory	Policy	Add policy	Success	
9/16/2026, 12:25:12 PM	Global Secure Access	ServiceManagement	Onboarding Process Sta...	Success	Onboarding process has been started for ...
9/16/2026, 12:21:31 PM	Access Reviews	Policy	Create access review	Success	
9/16/2026, 12:18:38 PM	Core Directory	ApplicationManagement	Add service principal	Success	
9/16/2026, 12:05:26 PM	Conditional Access	Policy	Add conditional access ...	Success	
9/16/2026, 12:05:26 PM	Core Directory	Policy	Update policy	Success	
9/16/2026, 12:05:25 PM	Core Directory	Policy	Add policy	Success	
9/16/2026, 11:53:54 AM	Conditional Access	Policy	Add conditional access ...	Success	
9/16/2026, 11:53:54 AM	Core Directory	Policy	Update policy	Success	
9/16/2026, 11:53:53 AM	Core Directory	Policy	Add policy	Success	
9/16/2026, 11:51:49 AM	Self-service Group Man...	GroupManagement	Features_SelfFeaturesSa...	Success	OK
9/16/2026, 11:51:00 AM	B2C	Authentication	Validate user authentica...	Success	Token is valid
9/16/2026, 11:50:44 AM	Core Directory	ApplicationManagement	Add service principal	Success	

ISO 27001 Reference: A.12.4.1 - Event logging. SOC 2: CC7.2 - System monitoring.

6. Advanced Identity Security Features

6.1 Named Locations

Named Locations define trusted and untrusted network locations for use in Conditional Access policies. A trusted headquarters IP range was created alongside a blocked countries location list for sanctioned regions - enabling location- based access controls that support both ISO 27001 A.9.4.1 and regulatory sanctions compliance.

Home > Audit Logs > ID Protection | Dashboard > Conditional Access

Conditional Access | Named locations

Microsoft Entra ID

Overview

Named locations are used by Microsoft Entra security reports to reduce false positives and by Microsoft Entra Conditional Access policies. Named Locations that are marked Trusted or configured in Conditional Access Policies cannot be deleted. [Learn more](#)

All Named Locations Deleted Named Locations

Search by name Location type: All types Trusted type: All types Reset filters

1 named location found

Name	Location type	Trusted	Conditional Access policies	Creation date	Modified date
All Compliant Network locations	Network Access	No	Not configured in any policy yet	9/16/2026, 12:25:13 PM	9/16/2026, 12:25:13 PM

Manage

- Named locations
- Custom controls (Preview)
- Terms of use
- VPN connectivity
- Authentication contexts
- Authentication strengths
- Classic policies

Monitoring

- Sign-in logs
- Audit logs

Troubleshooting & Support

- New support request

Home > Audit Logs > ID Protection | Dashboard > Conditional Access

Conditional Access | Named locations

Microsoft Entra ID

Overview

Named locations are used by Microsoft Entra security reports to reduce false positives and by Microsoft Entra Conditional Access policies. Named Locations that are marked Trusted or configured in Conditional Access Policies cannot be deleted. [Learn more](#)

All Named Locations Deleted Named Locations

Search by name Location type: All types Trusted type: All types Reset filters

1 named location found

Name	Location type	Trusted	Conditional Access policies	Creation date
All Compliant Network locations	Network Access	No	Not configured in any policy yet	9/16/2026, 12:25:13 PM

New location (IP ranges)

Upload Download

Configure named location IPv4 and IPv6 ranges. [Learn more](#)

Name *
NorthLink-HQ-Toronto

☒ Mark as trusted location

Enter a new IPv4 or IPv6 range
203.0.113.0/24

Add Cancel

Home > Audit Logs > ID Protection | Dashboard > Conditional Access

Conditional Access | Named locations

Microsoft Entra ID

Overview

Named locations are used by Microsoft Entra security reports to reduce false positives and by Microsoft Entra Conditional Access policies. Named Locations that are marked Trusted or configured in Conditional Access Policies cannot be deleted. [Learn more](#)

All Named Locations Deleted Named Locations

Search by name Location type: All types Trusted type: All types Reset filters

1 named location found

Name	Location type	Trusted	Conditional Access policies	Creation date	Modified date
All Compliant Network locations	Network Access	No	Not configured in any policy yet	9/16/2026, 12:25:13 PM	9/16/2026, 12:25:13 PM

Manage

- Named locations
- Custom controls (Preview)
- Terms of use
- VPN connectivity
- Authentication contexts
- Authentication strengths
- Classic policies

Monitoring

- Sign-in logs
- Audit logs

Troubleshooting & Support

- New support request

Home > Audit Logs > ID Protection | Dashboard > Conditional Access

Conditional Access | Named locations

Microsoft Entra ID

Overview Policies Deleted Policies Phased rollout Insights and reporting Diagnose and solve problems

Manage

- Named locations
- Custom controls (Preview)
- Terms of use
- VPN connectivity
- Authentication contexts
- Authentication strengths
- Classic policies

Monitoring

- Sign-in logs
- Audit logs

Troubleshooting > Support

- New support request

Named locations are used by Microsoft Entra security reports to reduce false positives and by Microsoft Entra Conditional Access policies. Named Locations that are marked Trusted or configured in Conditional Access Policies cannot be deleted. [Learn more](#)

All Named Locations Deleted Named Locations

Search by name Location type: All types Trusted type: All types Reset filters

2 named locations found

Name	Location type	Trusted	Conditional Access policies	Creation date
All Compliant Network locations	Network Access	No	Not configured in any policy yet	9/16/2026, 12:25:13 PM
NorthLink-HQ-Toronto	IP ranges	Yes	Not configured in any policy yet	9/16/2026, 1:10:19 PM

New location (Countries)

As of May 2023, both IPv4 and IPv6 addresses are mapped to countries/regions.

Name *

Blocked-Countries

Country lookup method

Determine location by IP address (IPv4 and IPv6)

Include unknown countries/regions

North

North Korea

North Macedonia

Northern Mariana Islands

Create Cancel

Home > Audit Logs > ID Protection | Dashboard > Conditional Access

Conditional Access | Named locations

Microsoft Entra ID

Overview Policies Deleted Policies Phased rollout Insights and reporting Diagnose and solve problems

Manage

- Named locations
- Custom controls (Preview)
- Terms of use
- VPN connectivity
- Authentication contexts
- Authentication strengths
- Classic policies

Monitoring

- Sign-in logs
- Audit logs

Troubleshooting > Support

- New support request

Named locations are used by Microsoft Entra security reports to reduce false positives and by Microsoft Entra Conditional Access policies. Named Locations that are marked Trusted or configured in Conditional Access Policies cannot be deleted. [Learn more](#)

All Named Locations Deleted Named Locations

Search by name Location type: All types Trusted type: All types Reset filters

3 named locations found

Name	Location type	Trusted	Conditional Access policies	Creation date	Modified date
All Compliant Network locations	Network Access	No	Not configured in any policy yet	9/16/2026, 12:25:13 PM	9/16/2026, 12:25:13 PM
Blocked-Countries	Countries (IP)	No	Not configured in any policy yet	9/16/2026, 1:12:05 PM	9/16/2026, 1:12:05 PM
NorthLink-HQ-Toronto	IP ranges	Yes	Not configured in any policy yet	9/16/2026, 1:10:19 PM	9/16/2026, 1:10:19 PM

6.2 Privileged Identity Management (PIM)

PIM provides just-in-time privileged access - instead of granting permanent admin rights, users request elevated access when needed, it gets approved, and it expires automatically after a set time. This directly supports the Principle of Least Privilege and addresses the privilege accumulation risk documented in RISK- 013 of the NorthLink Cyber Risk Register.

Home > Audit Logs > ID Protection | Dashboard > Conditional Access | Named locations > Privileged Identity Management | My roles > My roles | Microsoft Entra roles > Privileged Identity Management | Microsoft Entra roles

Roles

Quick start Overview Add assignments Refresh Got feedback?

Search by role name

Role	Description	Active	Eligible
Agent ID Administrator	Manage all aspects of agents in a tenant including identity lifecycle operations for agent blueprints, agent identity blueprints, agent identity blueprint principal in a tenant. User will be added as an owner of ...	0	0
Agent ID Developer	Create an agent identity blueprint and its agent identity blueprint principal in a tenant. User will be added as an owner of ...	0	0
Agent Registry Administrator	Manage all aspects of the Agent Registry service in Microsoft Entra ID	0	0
AI Administrator	Manage all aspects of Microsoft 365 Copilot and AI-related enterprise services in Microsoft 365.	0	0
AI Reader	Read all aspects of Microsoft 365 Copilot and AI-related enterprise services in Microsoft 365.	0	0
Application Administrator	Can create and manage all aspects of app registrations and enterprise apps.	0	0
Application Developer	Can create application registrations independent of the 'Users can register applications' setting.	0	0
Attack Payload Author	Can create attack payloads that an administrator can initiate later.	0	0
Attack Simulation Administrator	Can create and manage all aspects of attack simulation campaigns.	0	0
Attribute Assignment Administrator	Assign custom security attribute keys and values to supported Microsoft Entra objects.	0	0
Attribute Assignment Reader	Read custom security attribute keys and values for supported Microsoft Entra objects.	0	0
Attribute Definition Administrator	Define and manage the definition of custom security attributes.	0	0
Attribute Definition Reader	Read the definition of custom security attributes.	0	0
Attribute Log Administrator	Read audit logs related to custom security attributes.	0	0
Attribute Provisioning Administrator	Read and edit the provisioning configuration of all active custom security attributes for an application.	0	0
Attribute Provisioning Reader	Read the provisioning configuration of all active custom security attributes for an application.	0	0
Authentication Administrator	Can access to view, set and reset authentication method information for any non-admin user.	0	0
Authentication Extensibility Administrator	Customize sign in and sign up experiences for users by creating and managing custom authentication extensions.	0	0
Authentication Extensibility Password Administrator	Trigger a password submit or password update event for custom authentication.	0	0
Authentication Policy Administrator	Can create and manage the authentication methods policy, tenant-wide MFA settings, password protection policy, and ver...	0	0
Azure AD Joined Device Local Administrator	Users assigned to this role are added to the local administrators group on Microsoft Entra joined devices.	0	0
Azure DevOps Administrator	Can manage Azure DevOps organization policy and settings.	0	0

Home [redacted] Roles [redacted] Privileged Identity Management | Microsoft Entra roles

Quick start Overview Tasks My roles Pending requests Approve requests Review access Manage Roles Assignments Alerts Access reviews Discovery and insights (Preview) Settings Activity Resource audit My audit

+ Add assignments Refresh Got feedback?

Search by role: User Admin

Role	Description	Active	Eligible
Extended Directory User Administrator	Manage all aspects of external user profiles in the extended directory for Teams.	0	0
External ID User Flow Administrator	Can create and manage all aspects of user flows.	0	0
External ID User Flow Attribute Administrator	Can create and manage the attribute schema available to all user flows.	0	0
User Administrator	Can manage all aspects of users and groups, including resetting passwords for limited admins.	0	0

Home [redacted] Roles User Administrator | Assignments Privileged Identity Management | Microsoft Entra roles

Manage Add assignments Settings Refresh Export Got feedback?

Eligible assignments Active assignments Expired assignments

Search by member name or principal name

Name	Principal name	Type	Scope	Membership	Start time	End time	Action
No results							

Home [redacted] administrator | Assignments Role setting details - User Administrator Privileged Identity Management | Microsoft Entra roles

Edit

Activation

Setting	State
Activation maximum duration (hours)	8 hours
On activation, require	Azure MFA
Require justification on activation	Yes
Require ticket information on activation	No
Require approval to activate	No
Approvers	None
Require pre-approval custom extension to activate (Preview)	No
Require post-approval custom extension to activate (Preview)	No

Assignment

Setting	State
Allow permanent eligible assignment	Yes
Expire eligible assignments after	-
Allow permanent active assignment	Yes
Expire active assignments after	-
Require Azure Multi-Factor Authentication on active assignment	No
Require justification on active assignment	Yes

Send notifications when members are assigned as eligible to this role

Type	Default recipients	Additional recipients	Critical emails only
Role assignment alert	Admin	None	False
Notification to the assigned user (assignee)	Assignee	None	False
Request to approve a role assignment renewal/extension	Approver	None	False

Send notifications when members are assigned as active to this role

Type	Default recipients	Additional recipients	Critical emails only
Role assignment alert	Admin	None	False
Notification to the assigned user (assignee)	Assignee	None	False

Home > Calian Group | Roles > User Administrator | Assignments > Role setting details - User Administrator > Privileged Identity Management | My roles

My roles | Microsoft Entra roles Privileged Identity Management | My roles

Activate Refresh Open in mobile Got feedback?

Eligible assignments Active assignments Expired assignments

Search by role

Role	Scope	Membership	State	End time	Action
Global Administrator	Calian Group	Direct	Assigned	Permanent	Deactivate

ISO 27001 Reference: A.9.2.3 - Management of privileged access rights. SOC 2: CC6.1 - Just-in-time access provisioning.

6.3 Sign- In Logs & Risky Sign- Ins

Sign- in logs provide detailed records of every authentication event - IP address, location, browser, device, and Conditional Access policy evaluation results. Risky sign- ins are flagged automatically by Microsoft's AI- based Identity Protection when behavioral anomalies are detected (impossible travel, unfamiliar locations, anonymous IP addresses).

Sign-in events

Download Export data Settings Troubleshoot Refresh Manage view Got feedback?

Want to switch back to the legacy sign-in logs experience? Click here to leave the preview.

Add filter Show dates as: UTC Date range: Last 24 hours Reset filters

User sign-ins (interactive) User sign-ins (non-interactive) Service principal sign-ins Managed identity sign-ins

Date	Request ID	User principal name	Application	Status	IP address	Resource	Resource ID	Conditional access	User	Location
2026-09-16T14:36:41Z	fddee652-a...	kapilchaudhary...	Azure Portal	Success	260...	Azure Portal	c44b4d...	Not applied	Kapil Chaudhary	Toro
2026-09-15T20:31:44Z	8c7b51...	kapilchaudhary...	Azure Portal	Success	260...	Azure Portal	c44b4d...	Not applied	Kapil Chaudhary	Toro

Activity Details: Sign-ins

Basic info Location Device info Authentication details Conditional access Report only

Date: 2026-09-16T14:36:41Z

Request ID: fddee652-a...

Correlation ID: 4a868899-c...

Is Agent: No

Agent type: Not Agent

Agent subject type: Not Agent

Authentication requirement: Multifactor authentication

Status: Success

Continuous access evaluation: No

Additional details: MFA requirement satisfied by claim in the token

Troubleshoot event: Launch the Sign-in Diagnostic.

User: Kapil Chaudhary

User principal name: kapilchaudhary...

User ID: 6a95dd6b-a...

Sign-in identifier: 008ba51a-0...

Session ID: 008ba51a-0...

Root actor ID: 008ba51a-0...

App owner tenant ID: f8cde51a-0...

ID Protection | Risky sign-ins

Download Learn more Export data Settings Configure trusted IPs Troubleshoot Select all Confirm sign-in(s) compromised Confirm sign-in(s) safe Confirm sign-in(s) risk Refresh

Auto refresh: OFF Date: Last 7 days Show dates as: Local Risk state: 2 selected Risk level (real-time): None Selected Risk level (aggregate): None Selected Detection type(s): None Selected

Sign-in type: 2 selected Add filters

Date	User	IP address	Location	Risk state
				2 selected
				2 selected

Users can also have detections not linked to sign-in activity. To see all the detections, go to Risk detections.

ISO 27001 Reference: A.12.4.1 - Event logging. SOC 2: CC7.2 - Anomaly detection and monitoring.

6.4 Authentication Methods

Authentication methods configuration shows what MFA methods are available across the tenant - Microsoft Authenticator, SMS, email, FIDO2 security keys, and passwordless options. The activity report tracks MFA registration and adoption rates, identifying users or departments that have not enrolled - a control gap requiring remediation before audit.

Home > Settings > Authentication methods | Policies

Search [] + Add external MFA Refresh Get feedback?

Manage

- Polices
- Password protection
- Registration campaigns
- Authentication strengths
- Settings
- Monitoring
- Activity
- User registration details
- Registration and reset events
- Bulk operation results
- Bulk operation results (Preview)

Authentication method policies

Use authentication methods policies to configure the authentication methods your users may register and use. If a user is in scope for a method, they may use it to authenticate and for password reset (some methods aren't supported for some scenarios). [Learn more](#)

Method	Target	Enabled
Built-in		
Passkey (FIDO2)	All users	Yes
Microsoft Authenticator	All users	Yes
SMS	All users	No
Temporary Access Pass	All users	Yes
Hardware OATH tokens (Preview)	All users	No
Software OATH tokens	All users	Yes
Voice call	All users	No
Email OTP	All users	Yes
Certificate-based authentication	All users	No
Verified ID	All users	No
QR code	All users	No

Home > Settings > Authentication methods | Policies > Microsoft Authenticator settings

The Microsoft Authenticator app is a flagship authentication method, usable in passwordless or simple push notification approval modes. The app is free to download and use on Android/iOS mobile devices. [Learn more](#)

Enable and Target Configure

Enable ☒

Include Exclude

Target ☒ All users ☐ Select groups

Name	Type	Registration	Authentication mode
All users	Group	Optional	Any

Home > Settings > Authentication methods | Policies > Microsoft Authenticator settings > Authentication methods

Search []

Manage

- Polices
- Password protection
- Registration campaigns
- Authentication strengths
- Settings
- Monitoring
- Activity
- User registration details
- Registration and reset events
- Bulk operation results
- Bulk operation results (Preview)

Authentication methods | Activity

Registration Usage

Users capable of Azure multifactor authentication

0 of 5 total

100% of your organization isn't capable.

Users capable of passwordless authentication

0 of 5 total

100% of your organization isn't capable.

Users capable of self-service password reset

0 of 5 total

100% of your organization isn't enabled.

Users registered by authentication method

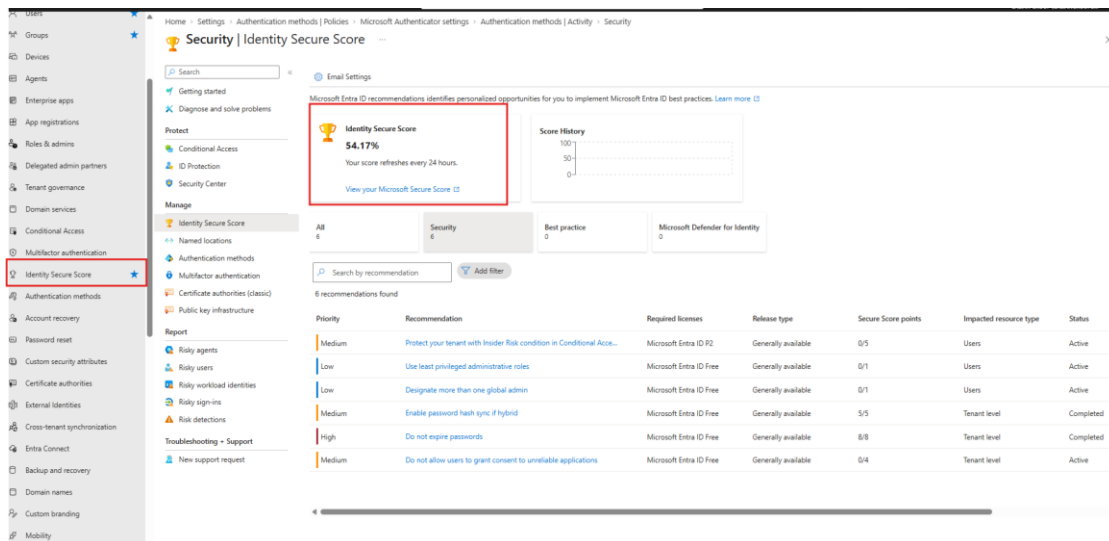
Method: All Reset filters

Recent registrations by authentication method

Date range: Last 7 days Method: All Reset filters

6.5 Identity Security Score

Microsoft's Identity Security Score provides automated security posture assessment with prioritized improvement recommendations sorted by score impact. This is a built-in tool for identifying security improvements and tracking progress.



ISO 27001 Reference: A.18.2.1 - Independent review of information security. SOC 2: CC4.1 - Monitoring of controls.

7. Conclusion

This project demonstrates end-to-end Identity and Access Management implementation in Microsoft Entra ID - from user provisioning and group-based access control through Conditional Access policy enforcement, automated access reviews, and advanced features including PIM, Named Locations, and Identity Protection.

Every configuration maps to specific ISO 27001:2022 Annex A controls, SOC 2 Trust Service Criteria, and PCI DSS requirements. The implementation follows enterprise best practices: policies deployed in Report-only mode before enforcement, break-glass accounts excluded from blocking policies, platform-by-platform rollout for device compliance, and quarterly automated access reviews with auto-revocation for unconfirmed privileges.

This is Project 1 of 5 in the Microsoft Security Portfolio. Subsequent projects cover Endpoint Compliance (Intune), Data Classification & DLP (Purview), Security Posture Assessment (Defender + Nessus), and Incident Response Playbooks.